

Data Retention and Disposal Policy

Organization: otterfund (unincorporated; operating name) **Product:** otterfund (<https://otterfund.ai>) **Policy owner:** Ibrahim Al-Tawil (Software Engineer) **Effective date:** July 21, 2026 **Version:** 1.0 **Review cadence:** Reviewed at least annually and after any material change to systems, data types, or applicable law. **Next review due:** July 21, 2027.

Hosting note: otterfund currently runs on the **free tiers** of Supabase (database/authentication) and Vercel (application hosting). The Supabase free tier does not include automated database backups; a move to paid plans is planned. The retention details below reflect the current free-tier configuration.

1. Purpose and Scope

This policy defines how long otterfund retains personal and financial data, how that data is securely disposed of, and how users exercise their rights to export and delete their data. It applies to all consumer data otterfund collects or receives — including data received from the Plaid API (account balances, transactions, investment holdings, account metadata), user profile and authentication data, uploaded bank statements, and billing records — across all systems and subprocessors listed in Section 6.

This policy is enforced through the retention periods in Section 3, the automated deletion mechanism in Section 4, and the review process in Section 8. It is compliant with applicable data-privacy laws including **PIPEDA (Canada)** and, where applicable, **GDPR** and **CCPA/CPRA**.

2. Retention Principles

- **Purpose limitation.** Personal and financial data is retained only as long as needed to provide the service, or as required to meet legal, tax, accounting, or dispute-resolution obligations.
- **Data minimization.** otterfund does not store users' bank login credentials (handled by Plaid) or full payment-card numbers (handled by Stripe).
- **Retain-until-deletion for active accounts.** Financial data tied to an active account is retained for as long as the account remains active, so the service can function, then disposed of per Section 4.

3. Data Categories and Retention Periods

Data category	System(s)	Retention
User profile (name, email, settings)	Supabase / Postgres	For the life of the account; deleted on account deletion.
Authentication identity / credentials	Supabase Auth	For the life of the account; deleted on account deletion.
Bank-connection tokens (Plaid access tokens, encrypted)	Postgres (AES-256-GCM)	For the life of the connection; revoked at Plaid and deleted when the bank is unlinked or the account is deleted.
Financial data from Plaid (accounts, transactions, holdings, balances)	Postgres	For the life of the account; deleted on account deletion or when the associated bank is unlinked.
Uploaded bank statements & AI-derived data	Postgres / processed via Anthropic	For the life of the account; deleted on account deletion.
Goals, budgets, categories, subscriptions, insights, advisor chats	Postgres	For the life of the account; deleted on account deletion (cascade).
Billing records (invoices, payment records)	Stripe	Retained by Stripe as required for tax/accounting/legal obligations, per Stripe's retention; customer object deleted on account deletion.
Application / security-event logs	Vercel + Supabase (free tiers)	Captured by the hosting platforms and retained only for the limited period their free tiers provide, then automatically rotated/purged. No extended log retention is configured.
Database backups	Supabase (free tier)	No automated backups exist on the current Supabase free tier. Deleted data is not copied to any backup and is permanently gone once deleted. Backup retention will be documented after the planned upgrade to a paid plan.
Aggregated / de-identified data (cannot reasonably identify a user)	Postgres	May be retained indefinitely, as it is no longer personal data.

4. Disposal and Erasure Mechanism

When a user deletes their account (self-service, available at any time), otterfund performs a full, irreversible erasure across all systems, in this order:

1. **Plaid** — every linked Plaid Item's access token is decrypted and passed to Plaid's `itemRemove`, revoking the bank connection at Plaid and stopping further data access and Plaid billing.
2. **Stripe** — the active subscription is canceled and the Stripe customer is deleted, purging billing PII and detaching

payment methods from otterfund's Stripe account (subject to Stripe's own legal-retention obligations for completed-transaction records). 3. **Primary database (Postgres)** — the user record is deleted, which **cascades via ON DELETE CASCADE foreign keys to every owned table**: accounts, transactions, categories, goals and allocations, subscriptions, investments, bills, budgets, insights, bank statements, Plaid items and link events, advisor conversations and messages, and AI-usage records. Billing-event audit rows without a cascade relation are deleted explicitly in the same transaction. 4. **Authentication (Supabase Auth)** — the auth identity is deleted so the login cannot be restored.

The database and authentication deletions are the authoritative wipe and are performed transactionally; the external revocations (Plaid, Stripe) are best-effort and logged so a provider outage cannot block a user from erasing their own data (any residual external reference is swept manually). Account deletion is rate-limited to protect against abuse and accidental double-submission, and is recorded as a security event.

Backups. otterfund currently runs on the **Supabase free tier, which does not provide automated database backups**. As a result, deleted data is **not** retained in any backup copy and is **permanently erased once deleted** — there is no backup from which it could be recovered. When otterfund upgrades to a paid plan that includes automated, encrypted backups, this policy will be updated to document the retention window after which deleted data ages out of backups.

Media / hardware disposal. otterfund runs on managed cloud infrastructure and does not operate its own storage hardware; secure media sanitization and destruction of underlying physical media are handled by the cloud providers (Supabase and Vercel) under their certified data-destruction processes.

5. User Rights

- **Export.** Users can export their data at any time via the in-app export function (`/api/settings/export`), which returns their data in a portable JSON file.
- **Deletion / erasure.** Users can permanently delete their account and associated data at any time via the in-app deletion function (Section 4).
- **Access / correction / objection / withdrawal of consent.** Users may exercise the rights described in the Privacy Policy by contacting privacy@otterfund.ai; requests are honored within the timeframes required by applicable law.

6. Subprocessor Data and Disposal

Data shared with subprocessors is limited to what each requires (see the Information Security Policy, Section 9, and the Privacy Policy). On account deletion, otterfund revokes/deletes the user's data at the subprocessors it controls (Plaid connection revoked; Stripe customer deleted; Supabase auth + data deleted). Subprocessors may retain limited records where required by their own legal obligations (e.g., Stripe's transaction records).

7. Legal Holds and Exceptions

Where otterfund is legally required to preserve specific data (e.g., an active legal dispute, regulatory request, or tax/accounting obligation), the relevant data is placed on hold and exempted from routine disposal for the minimum period required. Legal holds are approved and documented by the Policy Owner and released when no longer required.

8. Governance and Review

- This policy is reviewed at least annually and upon material change, and re-approved by the Policy Owner.
 - Retention periods and the deletion mechanism are validated periodically against the live system to confirm they operate as described.
 - Exceptions require documented Policy Owner approval with a defined scope and expiry.
-

Appendix — Confirmations before submission

- ☒ Company name (otterfund, unincorporated) and Policy Owner (Ibrahim Al-Tawil) set. Confirm **privacy@otterfund.ai** is monitored.
- ☒ **Log retention:** captured by Vercel + Supabase free tiers; limited free-tier retention, no extended log storage configured (Section 3).
- ☒ **Backup retention:** Supabase free tier has **no automated backups**; deleted data is permanently erased with no backup copy. Revisit when upgrading to a paid plan (Sections 3–4).
- ☐ Confirm **Stripe's** retention of billing records matches the statement in Sections 3 & 6.
- ☐ Set and calendar the **next annual review date**.